مراجعة مقارنة بين تقرير المشروع والنسخة البرمجية الحالية

حالة مشروع مسارك
المنجز، المتبقي، وأولويات الأمان

ملخص عملي للفريق قبل تحديد الخطوات التالية.

الخلاصة: توجد نسخة أولية تعمل لعرض المسارات، ومقارنة المهارات، وإظهار فجوات التعلم وحفظ بعض البيانات محليًا. لكنها ليست النظام الكامل الموصوف في التقرير: تسجيل الحسابات والتحليل بالذكاء الاصطناعي غير مفعّلين الآن، ولا يوجد ربط فعلي بقاعدة بيانات أو بيانات وظائف مباشرة أو محاكاة مقابلات.

ما الذي أُنجز؟

الميزة	الحالة	ما هو موجود فعليًا
واجهة التطبيق	منجز كنموذج أولي	تطبيق Expo وReact Native بواجهة عربية، وشاشات رئيسية للملف والمهارات والمسارات والخطة والسيرة الذاتية.
المسارات والتوصية	منجز مبدئيًا	مطابقة وحساب تغطية المهارات باستخدام بيانات ثابتة داخل المشروع لستة مسارات تقنية. ليست توصية مبنية على وظائف سوق متجددة.
فجوات المهارات	منجز مبدئيًا	عرض المهارات الأساسية المتوفرة والناقصة للمسار. النسبة الحالية هي تغطية مهارات، وليست قياسًا للإتقان أو ضمانًا للجاهزية الوظيفية.

الميزة	الحالة	ما هو موجود فعليًا
خطة التعلم	منجز جزئيًا	اقتراح مهارات لإضافتها إلى خطة محلية. لا توجد حتى الآن مكتبة مكتملة لدورات وشهادات وروابط تعلم موثقة من مصادر خارجية.
رفع وتحليل السيرة	الكود موجود، الخدمة غير مفعّلة	يوجد مسار لتحليل PDF وDOCX بخدمة Groq ومراجعة النتائج وحفظها محليًا. لكن مفتاح الخدمة والخادم غير مهيئين للتشغيل الحالي؛ وملفات PDF المصورة التي تحتاج OCR غير مدعومة.
تسجيل الدخول والحسابات	الواجهة والكود موجودان، غير مفعّلين	توجد شاشات ومنطق للمصادقة عبر Supabase، لكن إعدادات Supabase غير مضافة. لذلك لا يوجد تسجيل أو مزامنة سحابية فعالة الآن.
الحفظ الحالي	محلي فقط	بعض الملف والخطة تحفظ على الجهاز أو في قاعدة المتصفح. لا تنتقل تلقائيًا بين الأجهزة، ولا تحفظ في PostgreSQL حاليًا.

ما الذي لم يُنفّذ بعد من فكرة التقرير؟

المتطلب في التقرير	الحالة	المتبقي
وظائف ومتطلبات سوق العمل	غير موجود	جمع بيانات الوظائف، وتحديد مصدر مسموح وموثوق، وتحديثها دوريًا، واستخراج المهارات المطلوبة وربطها بالمسارات.
اتجاهات السوق ولوحة المؤشرات	غير موجود	تحليل بيانات وظائف كافية وعرض المهارات والاتجاهات بوضوح مع تاريخ المصدر وحدود العينة.

المتطلب في التقرير	الحالة	المتبقي
محاكاة المقابلة وتقييم الإجابات	غير موجود	أسئلة تقنية وسلوكية متكيفة مع المسار، استقبال إجابات المستخدم، ومعايير تقييم وتغذية راجعة.
قاعدة البيانات السحابية	التصميم فقط	إنشاء الجداول والعلاقات، وربط ملفات المستخدمين ونتائجهم بحساباتهم، وتطبيق صلاحيات وصول واختبارات أمنية.
لوحة الإدارة	غير موجود	تحديد دور المشرف وصلاحياته، ثم إدارة البيانات والمصادر ومراقبة الاستخدام دون إتاحة بيانات المستخدمين بلا داعٍ.
تقييم جودة النظام	اختبارات محدودة	قياس دقة استخراج المهارات والتوصيات، وتجربة استخدام منظمة، وتوثيق النتائج والقيود. وجود اختبارات لبعض الوحدات لا يثبت اكتمال هذا التقييم.

ملاحظة تقنية: التقرير يذكر Python للخادم؛ النسخة البرمجية الحالية تستخدم TypeScript في التطبيق وJavaScript/Node.js لخادم التحليل. وفيها اتصال مبرمج بـSupabase للمصادقة، لا قاعدة بيانات مستخدمين متكاملة.

إجراءات حماية موجودة حاليًا

- موافقة صريحة قبل إرسال نص السيرة إلى Groq، مع تنبيه للمستخدم بأن النص يرسل للخدمة الخارجية.
- الخادم لا يحفظ نسخة السيرة ولا يسجل محتواها بحسب الكود والتوثيق الحاليين.
- هناك حد لحجم الملف، وعدد صفحات PDF، وطول النص، مع قبول PDF وDOCX فقط والتحقق من محتوى الملف.
- تُراجع مخرجات التحليل مقابل نص السيرة وتُعرض للمستخدم للمراجعة بدل اعتمادها كحقائق مؤكدة.
- تُحفظ السيرة وبياناتها محليًا، مع خيار حذف السيرة المحفوظة من التطبيق.

نقاط أمان يجب معالجتها قبل استخدام بيانات حقيقية أو النشر العام

1. أولوية قصوى **لا تنشروا خادم تحليل السيرة للعامة بصورته الحالية.** الخادم لا يطلب تسجيل دخول ولا يربط الطلب بحساب مستخدم. حدّ الطلبات الموجود مؤقت وذاكرته محلية، ولا يحل محل التحقق من الهوية. إعداد CORS وحده ليس حماية من الاستخدام غير المصرح.
2. أولوية قصوى عند تفعيل Supabase، فعّلوا سياسات RLS على كل جدول بحيث لا يرى المستخدم إلا سجلاته. لا تضعوا مفتاح الخدمة السري (service role) في التطبيق؛ المفتاح العام لا يغني عن RLS.
3. أولوية قصوى احفظوا مفتاح Groq في أسرار الخادم فقط، ولا تضعوه في التطبيق أو متغير يبدأ بـ EXPO_PUBLIC_ أو في Git. لا ترفعوا سيرًا حقيقية قبل مراجعة سياسة الخصوصية وشروط مشاركة البيانات مع الخدمة الخارجية.
4. قبل التجربة استخدموا اتصال HTTPS من متصفح التطبيق إلى الخادم. المسار الموجود يفترض خادمًا محليًا على المنفذ 3001، وهذا لا يناسب صفحة Replit الآمنة مباشرة. يلزم ربط آمن من نفس النطاق قبل تجربة التحليل من المتصفح.
5. قبل التخزين السحابي حدّدوا مدة الاحتفاظ بالسيرة، والغرض من جمع كل حقل، وآلية حذف الحساب وبياناته والملفات. اشرحوا بوضوح ما يُرسل إلى مزودي الخدمات الخارجية ومن يستطيع الوصول إليه، وراجعوا متطلبات الخصوصية المعمول بها مع الجامعة والجهة القانونية المختصة.
6. قبل الإطلاق أضيفوا حماية من الإساءة: حدود طلبات موزعة، مهلة معالجة، مراقبة أخطاء بلا بيانات شخصية، وعزل معالجة الملفات وتحديث مكتبات PDF وDOCX. القيود الحالية مفيدة لكنها لا تكفي وحدها ضد الضغط أو الملفات المصممة للإضرار.
7. دائمًا اعتبروا السيرة ومدخلات المستخدم نصًا غير موثوق. يجب ألا تتحول تعليمات داخل الملف إلى أوامر للنموذج أو للنظام. راجعوا مخرجات الذكاء الاصطناعي ولا تعرضوا نسبة التغطية كحكم قطعي على قبول وظيفي أو إتقان.

للتجربة الآن: استخدموا حسابًا تجريبيًا وسيرة وهمية، ولا تشاركوا بيانات شخصية حقيقية مع النموذج قبل اتخاذ قرار واعٍ بشأن الخصوصية.

ترتيب عملي مقترح للخطوات القادمة

1. **تحديد نسخة العرض المطلوبة:** هل المطلوب الآن عرض جامعي يعمل دون حساب، أم تجربة مستخدمين بحسابات، أم استكمال جميع وظائف التقرير؟
2. **تثبيت النطاق والأولوية:** الاتفاق على ما يدخل في النسخة النهائية، خصوصًا مصدر وظائف السوق ومحاكاة المقابلات، قبل توسيع البرمجة.

3. **إغلاق أساس الأمان والبيانات:** سياسة الخصوصية والموافقة، طريقة الحسابات، قاعدة البيانات وصلاحيات RLS، وربط الخادم الآمن.
4. **تنفيذ الميزات الناقصة تدريجيًا:** بحسب الأولوية والوقت، ثم اختبارها مع مستخدمين وتوثيق نتائج التقييم والقيود.

أساس هذه المراجعة: تقرير المشروع المرفق وملفات التطبيق والخادم الموجودة في النسخة الحالية. هذا تقرير مطابقة أولية وليس اختبار اختراق أو اعتمادًا قانونيًا؛ ينبغي إجراء مراجعة أمنية متخصصة قبل النشر العام.